

D3-FI 安全事件响应手册(Incident Response Runbook · v2)

原则:先止血(暂停)→再取证→再修复→多人审批恢复。暂停可单人即时执行;恢复(unpause)必须双人审批。认证现为 SIWE(EIP-4361):会话令牌是用 SIWE_SESSION_SECRET 做 HMAC 的 JWT,身份即令牌主体钱包。工具:admin-panel「安全中心」页 / POST /admin/security/pause / system_pause_flags / security_alerts / 审计日志 audit_logs (不可改删) / npm run security:preflight。

0. 通用响应流程(所有事件)

1. **止血**:在「安全中心」关闭相关熔断开关(或 POST /security/pause {flag,reason})。
2. **取证**:查 security_alerts (触发规则)、audit_logs (操作者/前后值)、链上交易、partner_yield_withdrawals / deposit_records / treasury_ledger。
3. **定级**:P0(资金/权限/认证)立即全员 + 电话值班;P1 立即人工审核;P2 当天处理。
4. **修复 + 恢复**:根因修复后,由**第二位不同管理员**经审批中心 approve security.unpause 恢复。
5. **复盘**:记录时间线、影响金额、根因、改进项,更新监控规则/限额。

1. 虚假 / 重复充值

- **信号**:告警 deposit_duplicate_tx / deposit_burst ;链上充值与内部入账不符。
- **止血**:暂停 deposits。
- **核查**:deposit_records 按 (chain_id, tx_hash, log_index) 去重是否被绕过;verifyUsdtTransfer 的合约/金额/确认数;是否假币(核对 BSC_USDT_CONTRACT ;注意测试期结算币为水龙头币 R-2)。
- **处置**:回滚未结算的错误入账;受影响用户单独核对;确认幂等唯一索引仍在。

2. 重复奖励 / 业绩虚增

- **信号**:同一 source 多次发奖;performance_weight 异常增长。
- **止血**:暂停 rewards 与 settlement。
- **核查**:partner_yield_settlements (position_id+date 唯一)、partner_ud3_events (intent 唯一)是否被绕过;两阶段结算 pending_ud3 / settle_pending_ud3 是否异常(见 R-7:出错被吞会致少记滞留);是否 report-tx 重放。
- **处置**:冲正重复奖励(记审计);修复幂等门控后恢复。

3. 闪兑钱包异常流失 / 被盗

- **信号**:告警 P0 偿付率击穿(已自动暂停 flash_swap)、平台每小时闪兑量超限;Swap 钱包余额骤降。
- **止血**:确认 flash_swap 已暂停(未暂停则立即暂停);必要时暂停 treasury。
- **核查**:partner_yield_withdrawals 近窗口订单 vs 链上支付;是否并发双花 / 退款双付;收款地址是否异常;Turnkey 签名活动。
- **处置**:核对原子扣减 + 在途唯一 + 退款门控是否生效;补足储备后**双人审批恢复**;必要时下调 risk_limits。

4. Treasury 金库异常出账

- **信号**:金库余额下降未匹配内部流水;Safe/Turnkey 权限变更。
- **止血**:暂停 treasury ;若疑似凭证泄露,走事件 7。
- **核查**:金库出账是否经多签/quorum;是否 /admin/turnkey/approve-consensus 被滥用;Owner/Threshold/Policy 是否被改。
- **处置**:冻结自动出账;链上追踪;核实 root quorum≥2 与凭证隔离。

5. D3 价格源被操纵

- **信号:**告警 `d3_price_stale` / `d3_price_swing`。
- **止血:**价格失效已自动拒付(收益/闪兑);必要时暂停 `settlement + flash_swap`。
- **核查:** `d3_price_settings` 最近变更(审计)、偏差是否超 `max_deviation_pct`、`expires_at`。
- **处置:**按可信来源重设价格(须通过护栏 + 双人复核);核对受影响期间的产出/赎回。

6. 认证系统被攻破 / SIWE 会话密钥泄露(P0,最高优先)

现认证以 `SIWE_SESSION_SECRET` 对会话令牌做 HMAC。该密钥一旦泄露,攻击者可为任意钱包伪造有效会话令牌,冒充任何用户操作其资金;而当前令牌无 `jti`/无吊销表(R-8),故——**信号:**同一钱包异常地点/设备的资金操作;大量账户短时异常操作; `SIWE_SESSION_SECRET` 疑似外泄(日志/仓库/环境泄露); `/auth/*` 异常流量。— **止血(kill-switch):**立即轮换 `SIWE_SESSION_SECRET` (≥ 32 字符, `supabase secrets set` 后重部署)——这会**使全部现有会话令牌立即失效**,是唯一的全局吊销手段;同时暂停 `flash_swap + treasury + settlement + rewards`,直到确认。— **核查:**泄露来源与时间窗;该窗口内的所有资金操作 (`audit_logs` / `partner_yield_withdrawals` / `treasury_ledger`); `SIWE_ALLOWED_DOMAINS` 是否被篡改(是否新增钓鱼域名); `siwe_nonces` 是否异常膨胀。— **处置:**轮换后强制全体用户重新登录(SIWE 签名);回滚窗口内的非法资金操作;修复泄露源(密钥仅存 Edge secrets,绝不入 Git/前端);上线后加令牌 `jti` + 吊销表(R-8)、缩短 TTL。

7. Turnkey / 签名凭证泄露

- **止血:**暂停 `flash_swap + treasury + settlement`;吊销/轮换泄露的 Turnkey API key 与 `TREASURY_CRON_SECRET`。
- **核查:**近期 Turnkey 签名活动、Policy 变更、是否任意签名被利用。
- **处置:**提升 root quorum;将金库/cosigner 密钥移出边缘环境;重新执行收敛策略 `npm run turnkey:policies`。(链上多签仍可选用 `privyApi`——如涉及一并轮换。)

8. 管理员账户被盗 / 越权

- **信号:**异常 IP/新设备登录;高危 admin 审计;maker-checker 被绕过尝试。
- **止血:**吊销该 admin 会话;临时收回 `security.write` / `subsidies.write`。
- **核查:** `audit_logs` (不可改删)全部该 admin 操作; `admin_action_approvals` 是否自审批(已被 `assertDifferentApprover` 拦截)。注意 R-3:修复前 `subsidies.write` 者可越权批准 `security.unpause` / `risk_limits`——重点核查审批人权限是否匹配 action。
- **处置:**回滚其付款类改动;强制改密 + 2FA;复核角色权限最小化;尽快落地 R-3(审批按 action 校验权限)。

9. 数据库被直接篡改(应用层被绕过)

- **信号:**余额/价格/多签行与账本不符,但无对应 API 审计。
- **止血:**暂停相关资金功能;确认 RLS 生效(anon 应 401)与 `SUPABASE_SERVICE_ROLE_KEY` 是否泄露。
- **核查:**余额非负 CHECK、审计不可变规则、幂等唯一约束、`siwe_nonces` RLS 是否仍在(跑 `npm run security:preflight`);Merkle 锚 `daily_state_anchors` 比对。
- **处置:**若 service_role key 泄露 → 立即轮换;按锚定/账本重算修复。

10. RPC 攻击 / reorg

- **止血:**高价值充值提高确认阈值;付款已要求 ≥ 12 确认。
- **核查:**多 RPC 交叉验证; `deposit_records` 是否有已入账但被 reorg 的交易。
- **处置:**回冲被 reorg 的入账;充值全回滚为路线图,期间人工盯高额充值。

11. 智能合约漏洞

- **止血:**若合约有 `pause` 则暂停;停止相关链上交互;必要时暂停 `deposits` / `treasury`。

- **核查**:特权角色、升级权、异常 approve/授权;ReferralRegistry 角色是否仍在热 EOA(R-10)。
- **处置**:UUPS 升级前经多签 + timelock;修复后再开放。

12. 认证接口滥用 / DoS(R-5)

- **信号**: `/auth/nonce`、`/auth/verify` 异常高频; `siwe_nonces` 表快速膨胀;边缘函数 CPU/延迟升高(签名恢复开销)。
- **止血**:在网关/CDN(Cloudflare)对 `/auth/*` 加限流/WAF;必要时临时封禁来源 IP。
- **核查**:来源 IP/地址分布;是否伴随伪造登录尝试。
- **处置**:落地 `/auth/*` 按 IP+地址限流 + nonce 过期清理任务(R-5)。

恢复(Resume)标准流程

1. 根因已修复且验证(必要时补 `npm run security:preflight` ,要求 PASS)。
2. 第一位管理员在「安全中心」发起 unpause(生成待审批)。
3. **第二位不同管理员**在审批中心 approve `security.unpause` (系统强制 `assertDifferentApprover` ;注意 R-3 权限修复)。
4. 若曾轮换 `SIWE_SESSION_SECRET` :确认已重部署且用户可正常重新登录。
5. 恢复后 30 分钟内加密盯盘;告警清零后关闭事件。

值班与升级

- P0(含认证被攻破):电话/SMS + Telegram/Slack,全体安全负责人,≤15 分钟响应。
- P1:Telegram/Slack + 邮件,≤1 小时进入人工审核。
- P2:告警中心,当天处理。
- 告警/通报脱敏:严禁包含私钥、完整 API key、`SIWE_SESSION_SECRET` 、会话令牌、DB 密码。

关键密钥轮换速查

泄露	影响	立即动作
<code>SIWE_SESSION_SECRET</code>	冒充任意用户	轮换 → 全会话失效 + 全员重登(事件 6)
<code>SUPABASE_SERVICE_ROLE_KEY</code>	直改任意库表(绕 RLS)	轮换 + 查审计/锚定重算(事件 9)
<code>TURNKEY_API_PRIVATE_KEY</code>	签热钱包交易	轮换 + 收敛策略 + 提升 quorum(事件 7)
<code>TREASURY_CRON_SECRET</code>	触发内部/结算/归集	轮换 + 移出 pg_cron 明文